ICT Information Security -- Final exam

Time allowed: 90 minutes

*Paper documents are allowed but smart phones and computers are **NOT**!*

*Per each student, let **X** be the number determined by the last two digits of your Student Number (e.g. SN=* 1234567890 ➔ **X**=90). *Also, let **Y = X mod 4**.*

1. **(4.5 pts) If (your) Y=0 then do a&c&e, Y=1 do b&d&e, Y=2 do b&c&f and Y=3 do a&d&f. Explain by brief but clear arguments.**

   Bài này có 3 nhóm câu hỏi theo trình độ tăng dần: dễ, trung bình, và hơi thách thức 1 chút

a) Considering to construct an RSA scheme with modulo *n=p*q*, find proper primes numbers *p* and *q* between (Y+3)*4 and (Y+6)*4. What is the smallest integer *e>20* that can be a proper exponent?
b) Find *p* & *q* and *n* as asked in part a). What is the largest integer *e* <30 that can be a proper exponent?

Đây là các bài có tính chất "tặng điểm", tuy nhiên để được toàn bộ 1.5 cũng cần dẫn giải có lời lẽ. Nếu chỉ viết các biểu thức và ký hiệu suy diễn, thiếu sự dẫn dắt bằng câu văn (một vài câu) thì sẽ chưa được 1.5 Ví dụ: nếu cần tìm giá trị lớn nhất e>20 để thỏa mãn điều kiên đề ra và các em chọn e=23 thì cần nêu rõ tại sao e=21,22 là không phù hợp.

c) Compare the 2 encryption modes CBC and CFB. Do the latter have any advantage over the former?
d) Compare the 2 encryption modes CFB and OFB. Do the latter have any advantage over the former?

Trong 2 câu hỏi tương đương tiếp theo này, nếu muốn được ful 1.5 thì các em cần so sánh tương đối đủ ý, ít nhất có 3 ý trở lên, chẳng hạn như 2 điểm giống và 1 điểm khác biệt rõ nét nhất là gì. Từ sự khác biệt đó, tiếp tục lập luận để chỉ ra lợi thế của chế độ này so với chế độ kia.
Trong bài này không cần mô tả dài dòng (chép từ tài liệu) mà chỉ tập trung nếu nổi bật các điểm nói trên, mỗi ý khoảng 2-3 câu văn là được.

e) Discuss the importance of the *least privilege* principle in designing access control mechanism. Compare and contrast the possibility of applying this principle in DAC vs. MAC vs. RBAC

Thứ nhất cần nêu và phân tích ý nghĩa 1 cách kỹ lưỡng về khái niệm LPP này. Tại sao nên chú ý đảm bảo yếu tố này trong thiết kế điều khiển truy nhập. Sau đó lần lượt phân tích sự khả thi của việc đảm bảo LPP trong từng mô hình điều khiển truy nhập : DAC, MAC và RBAC. Cần nếu rõ tính khả thi là tốt nhất ở đâu, kém nhất ở đâu. Hoặc ở mô hình nào đó thì không phải hoàn toàn khả thi mà cũng không hoàn toàn bất khả thi: chỉ là đáp ứng một phần nào đó… Các em có thể có ý kiến riêng của mình, miễn là biết cách trình bày suy luận của mình cho hợp lẽ.

f) Can you find a concept in DAC that possesses some equivalence to the concept of *role* in RBAC? Compare and contrast these two.

Khái niệm tương đương rất rõ nét với role trong RBAC là group trong DAC. Sự tương đồng là rất rõ một role X hay group X đều là 1 định danh chủ thể tính biểu tượng, mà nó có thể nhận được cấp phát của 1 tập các quyền truy nhập: Tập các quyền này sẽ lập tức được chuyển giao cho 1 user Y nào đó khi nó được gán nhãn X này. Tất nhiên cần phát triển và làm rõ nét, thêm ý và chi tiết cụ thể vào nhận xét khái quát trên.

Câu này có rất nhiều bạn làm sai, ví dụ như so sánh role với khái niệm chủ nhân (Owner) trong DAC ... Tuy rất không thích hợp nhưng vì các bạn cũng có viết được 1 số kiến thức riêng đã nắm bắt được nên cũng được điểm "khuyến khích" từ 0.5 đến 0.75

2. (3.5pts) Assume that H is a cryptographic hash function with output size (Y+2)*16 bits. Assume that Scorpion-***i*** (***i***=1-9) is a specifically designed line of hardware chips for computing H where Scorpion-***i*** can create 10^i hash values a second (e.g. Scorpion-2 can do 100 hashes/sec). This product line is the best, fastest and affordable, in the market, priced at $\boldsymbol{i}^{i/2}$ *$1000 (e.g $2000 for *i*=2, $16000 for *i*=4).

a) The computer host of a bank center is connected to 100 branches which have to constantly report to the host by sending numerous datafiles of 3 specialized formats A,B and C with fixed sizes of 1100, 1500 and 1800 bytes, respectively. The data is sent in packets of size 512 bytes, including a MAC code computed using the Scorpion chips mentioned. The bank host is expected to receive up to 4Gbytes data per hour with at least (Y+5)*10% in C-datafiles. At least how much the bank needs to invest on the Scorpion chips?

*Câu hỏi này thuộc loại "hơi dễ", chỉ cần hiểu biết cơ bản về hệ thống mạng. Mỗi packet độ dài 512 byes sẽ có 1 đoạn MAC code gắn kèm (mã kiểm tra tính nguyên vẹn), được tính như là giá trị băm của dữ liệu chính. Dễ thấy môt file A cần 3 packet, B cần 3, và C cần 4 packet: packet cuối cùng sẽ là phần bị hụt không đủ 512 ("đầu thừa đuôi thẹo"); so sánh sự thiếu hụt khác nhau sẽ dẫn đến thấy rằng dữ liệ kiểu A sẽ "tốn" packet nhiều nhất, còn loại B là "kinh tế" nhất. Vì vậy có thể tính được tình huống xấu nhất mà nhà bank phải chuẩn bị: (Y+5)*Y% dữ liệu là loại C và còn lại là loại A.*

Tuy nhiên không cần các em phải lập luận quá kỹ và chi tiết, chỉ cần thấy có ý gần đúng và triển khai sạch sẽ là thầy cho điểm gần tối đa.

b) An authentication mechanism created for an Internet website is based on a challenge-response phase where the host challenges the user by sending a random 20-bit message r_1 and the user has to response with $H(h_p||r_1)$ where $h_p = H(p||r_2)$ is a hash image of the user password, secretly shared between the two sites with r_2 as a 15-bit random. A hacker wants to steal the password of a VIP user A and so, has built a dictionary of 100,000 possible password guesses and managed to capture some authentication transaction data through wiretapping A's connection to the website. How much the hacker has to invest on the Scorpion chips to make the steal possible in 3 days?

Câu này thuộc loại trên trung bình. Điểm then chốt là phải nghĩ ra với mỗi dự đoán mật khẩu thì hacker sẽ cần test thử như thế nào: cụ thể là phải làm bao nhiêu phép băm?
Để làm được điều này thì cần "phục dựng" lại quá trình thực hiện trong giao thức và biết được hacker sẽ thu, ghi lại được gì từ việc nghe trộm; chính là một vài cặp r_1 và $Y= H(h_p||r_1)$, trong đó $h_p = H(p||r_2)$. Vì vậy với mỗi giá trị p dự đoán có thể thay thế tất cả các khả năng của r_2 để kiểm tra. Với mỗi r_2 sẽ cần làm 2 phép băm rồi kiểm tra xem đẳng thức nói trên có xảy ra ... Từ những điều này có thể tính được tổng số lần băm cần thiết ... Tất nhiên ở trên chưa nói rõ bao nhiêu lần băm cần thực hiện với mỗi phần tử p trong từ điển: hy vọng các em tự thấy dễ dàng

3. (2 pts) During year 2020, two powerful computer hosts A and B secretly communicate heavily through Internet with average 1000 sessions per day, using a customized version of Needham-Chroeder protocol that would be replaced by the beginning of 2021. Different to the original protocol (discussed in class), in step 4 B challenges A by computing and sending $r_2 \oplus H^{70}(k_s)$ and A has to respond with message $r_2 \oplus H^{30}(k_s)$ where r_2 is a random with the size in bit equal to H's

output size, and $H^k(t)$ is the hash chain – successive application of H (as in prob. 2 above) to given t : $H^k(t) = H(H^{k-1}(t))$.
Hacker Eve has secretly wiretapped the A-B communication and recorded all the data transfer between A and B for a whole year 2020. On Dec 30th, Eve then luckily captured an old session key k_s that has been used by A and B during 2020, i.e. Eve has 24 hours to find a way to take advantage of this k_s. How much Eve needs to spend in these Scorpion chips in order to achieve the target?

Bài này là tương đối thách thức, tuy nhiên bài này đã được giảng trên lớp trong khuôn khổ về tấn công biết khóa cũ đối với giao thức Needham-Schroeder, phần phân tích nâng cao. Ai cũng biết là kẻ địch có thể tấn công phát lại, dùng thông điệp số 3 của giao dịch giữa A và B trong session đã dùng khóa cũ mà E tình cờ lấy được. Nhưng như ta thấy một ngày có hàng ngàn phiên giao dịch giữa A&B, và cứ như vậy suốt cả năm 2020. Nếu E muốn tìm cho đúng cái hồ sơ giao dịch của cái chính xác cái phiên ứng với khóa cũ đó, thì có nghĩa là phải "lục lọi" từ cái kho đã "thu băng trộm" của hàng trăm nghìn phiên. Với từng giao dịch phiên sẽ phải tính toán thử khá nhiều để kiểm tra xem có khớp không ➔ sẽ tính được bao nhiêu phép băm cần làm để kiểm tra thử dữ liệu của 1 phiên giao dịch ➔ tính khái lược số phép băm tối đa cần thiết cho toàn bộ công cuộc tìm kiếm ➔ tính ra số tiền đầu tư vào Scorpion chip